Udyvia: Privacy note

What this covers. How Udyvia handles an owner's data from first chat to order tracking. Every statement below matches behaviour in the code and is covered by tests in `backend/tests/test_privacy.py`. This note describes our design choices; it is not legal advice.

What we collect, why, and for how long

Data	Why we need it	Kept for
Business type, headcount, locations, city, GST yes/no, needs	To recommend a bundle and price it	24 hours (72 hours for a quote that never becomes an order)
GSTIN, only if the owner types it	To unlock GST-only products	Same as chat answers
Four KYC documents (images) and the fields read from them	To verify the business against the GST and Udyam registers	24 hours, or until the owner withdraws
Signatory name (e-sign) and, optionally, a phone number	To record the agreement; to send order updates	Order record: 30 days in this demo. Phone: only the last 4 digits are stored

We do not collect anything else. No account, no email, no location, no contacts. The browser keeps nothing between visits.

Consent and control

- **Before any upload** the owner sees a notice with the purpose, the data used, the retention period and how to withdraw. Uploads are refused without it.
- **Withdraw at any time** with one tap: uploads and results are deleted immediately.
- **Automatic deletion.** A job runs every 10 minutes and deletes anything past its retention period, whether or not anyone is using the service. Files left behind by a restart are swept on startup and on every run. Retention periods live in one file and the consent notice reads from it, so what we say is what runs.

Where data goes

- **Documents never leave our server.** They are read with local OCR and checked against the registers. No document image or OCR text is sent to any AI service.
- **The chat uses an AI model (Gemini)** only to turn free text into fields and to phrase the explanation. Before sending, GSTIN, Udyam, phone, email and 12-digit ID numbers are replaced with placeholders. A typed GSTIN is validated in our own code. Prices, eligibility and KYC decisions are always computed by our rules, never by the model.
- **Voice (Azure AI Speech)** reads the advisor's replies aloud, only when the owner taps Listen or turns on read-aloud. It receives the reply text only, with identifiers replaced by placeholders. The owner's own messages and all documents stay out. We log only the length of each request.

Masking and logs

- Identifiers are masked on screen (for example `32•••••••••T1ZW`) and in every API response.
- A filter scrubs all application and server logs, so an identifier cannot be logged even by mistake.
- The audit trail records events, order ids, counts and decisions only (for example "consent given", "KYC decided: PASS"). Never names, numbers, addresses, document content or chat text. A test runs a full order and searches the trail for any identifier.

Safeguards

Session and order ids are random and unguessable. Uploaded files sit in an owner-only folder (permission bits on Linux and macOS; the per-user temp folder on Windows), limited to PNG or JPEG under 8 MB, and stored under server-chosen names.

Limits of this prototype, and what production needs

Data is held in memory and the GST, Udyam, e-sign and payment services are mocks. There is no login yet, so access rests on unguessable ids. For production: OTP login, encrypted storage, a database-backed retention job, India-region hosting, written agreements with every processor, a breach-response process and a named grievance contact. The AI provider's data terms must be confirmed: free tiers can allow inputs to be used for product improvement, so production should use a tier that does not train on inputs.